



Developing the Security Assessment Plan (SAP)

DEVELOPING THE SECURITY ASSESSMENT PLAN (SAP)



GRC GATE TRAINING

The left side of the slide features a decorative background with vertical columns of binary code (0s and 1s) in white and yellow. Overlaid on this are several padlock icons in yellow and blue, some of which are open and some are closed.

Introduction to Security Assessment Plan (SAP)

SAP development is a strategic, foundational phase for cybersecurity assurance

- Ensures information systems are thoroughly and risk-aligned evaluated

SAP is not just documentation, but enables maintenance of trust and regulatory compliance

- Acts as a linchpin for organizations to meet requirements and protect assets

Applies to both government agencies and private enterprises

- SAP protects critical assets from evolving threats in all sectors

Purpose and Importance of SAP

SAP serves as a blueprint for security assessments

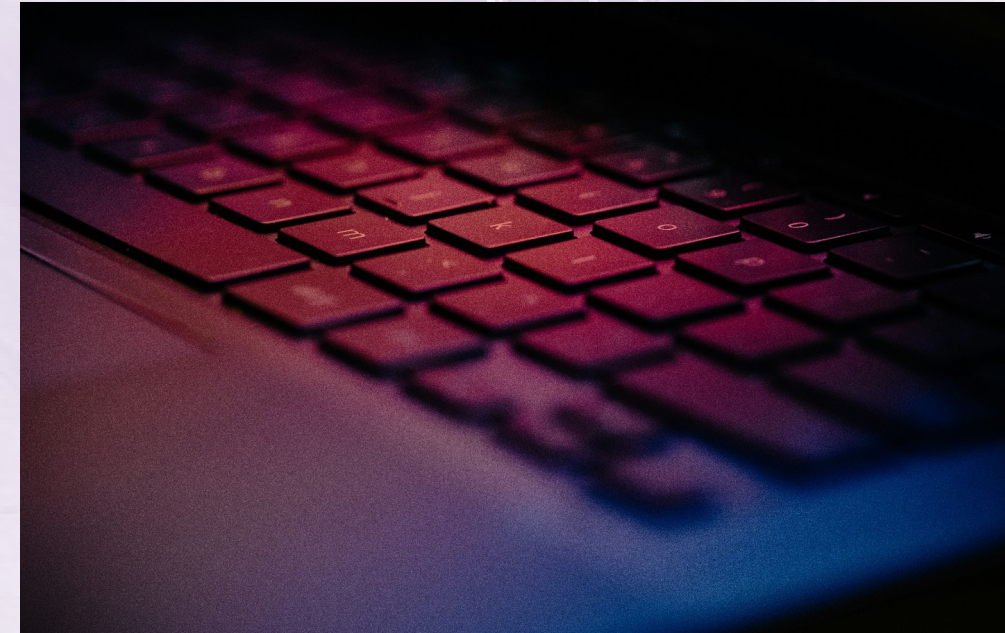
- Outlines what, how, and who regarding assessment activities

Aligns all stakeholders with purpose, boundaries, and expectations

- Ensures assessors and system owners share a common understanding

SAP is foundational within the Risk Management Framework (RMF)

- Guides assessment phase and aligns with organizational goals





Core Elements of SAP – Objectives

Objectives explain why assessment is being conducted

- Must be specific, measurable, achievable, relevant, and time-bound

Specific objectives prevent misunderstandings and missed risks

- For example, validating access control measures within 30 days

Vague objectives can result in oversight of critical controls

- Real-world cases show gaps in risk awareness when objectives lack clarity

Core Elements of SAP – Scope

Scope defines what systems and components are assessed

- Includes detail on systems, networks, applications, and data

Specifies boundaries, interfaces, and exclusions

- Should clarify on-premise, cloud, external links, and omitted areas

Clear scope prevents scope creep and resource dilution

- Exclusions and focus areas must be justified and documented in the SAP





Core Elements of SAP – Methodology

Methodology details assessment techniques, tools, and processes

- Can include interviews, document reviews, technical testing, and inspections

Outlines activity sequence, responsibilities, and control evaluation criteria

- Includes details for specific tests like social engineering or log analysis

Ensures assessment repeatability and objectivity

- Methodology is essential for trustworthy, consistent assessments

Selection of Controls and Tailoring of Procedures

SAP must select relevant controls from an organizational catalog

- Selection based on system categorization, risk, and regulatory needs

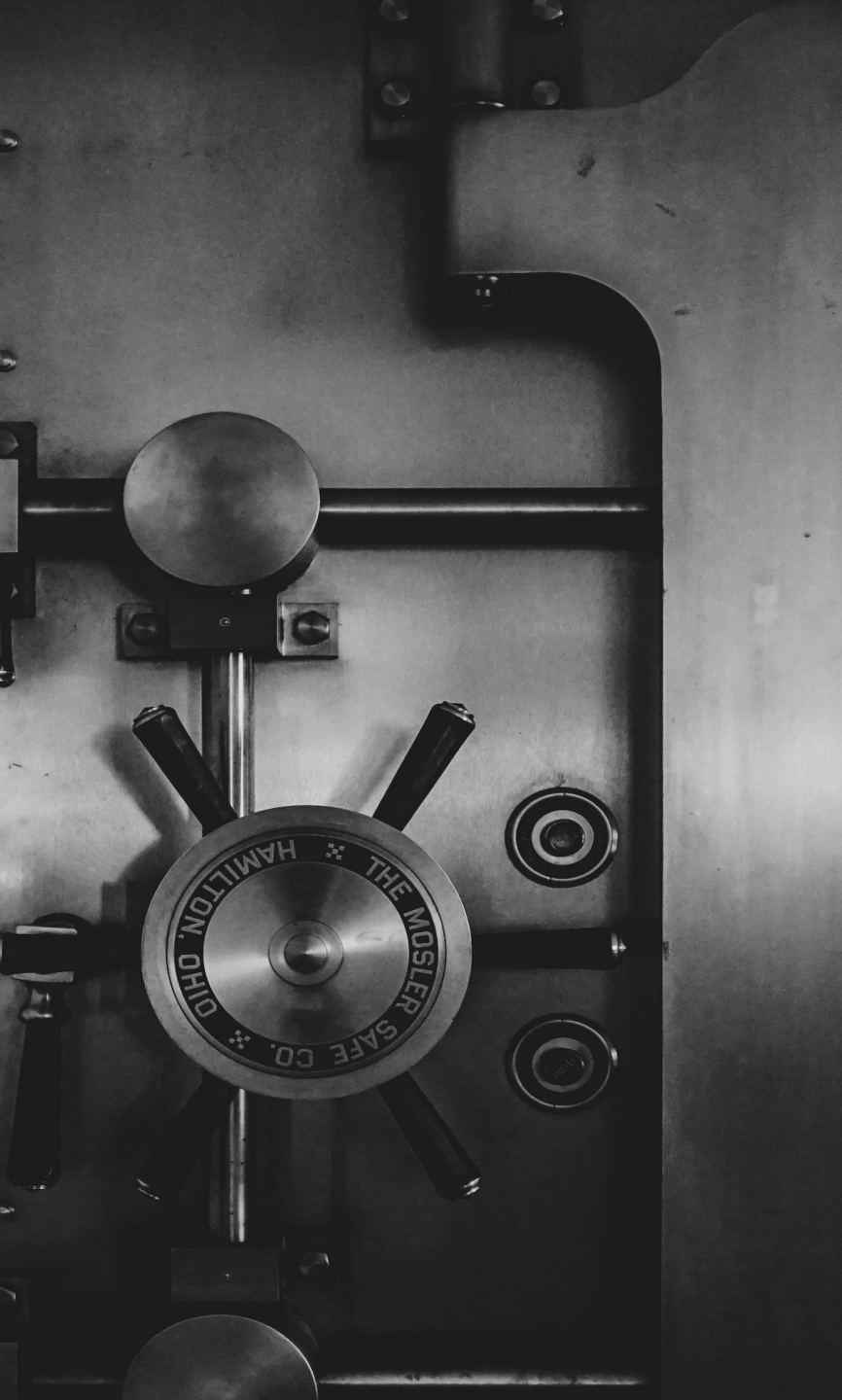
Control choices influenced by system type (e.g., healthcare vs public web)

- Prioritizes appropriate control areas like privacy or web security

Tailoring of assessment procedures addresses control implementation differences

- Adapts testing for variations like multifactor authentication setups





Sampling Techniques and Depth of Testing

Sampling is essential for efficiency in large systems

- Tests reasonable assurance using subsets (e.g., 10 out of 100 accounts)

Specifies sampling methodology appropriate to risk and context

- Can use random, stratified, or targeted sampling approaches

Depth of testing balances thoroughness with efficiency

- SAP defines depth per control, e.g., documentation review or technical validation

Assessment Deliverables and Timelines

SAP must list expected deliverables for the assessment

- Includes reports, executive summaries, findings matrix, and recommendations

Details format, content, intended audience, and required follow-up

- Customizes outputs for both technical teams and senior management

Timelines should include clear milestones and schedules

- Outlines key events like kickoff, data collection, and report delivery





Coordinating SAP Approval with Stakeholders

Involves review and input from key stakeholders

- Includes system owners, security officers, risk managers, business leaders

Approval process provides accountability and commitment

- SAP is formally signed off after alignment with priorities and requirements

Challenges include varied priorities and interpretations

- Solutions are frequent communication, transparent documentation, and adaptability

Real-World Example of SAP Application

Objectives: verify confidentiality and integrity of customer data controls

- Focus covers data-handling modules, excludes non-sensitive subsystems

Methodology: involves review, technical testing, and interviews

- Tests encryption, access, and auditing controls in both on-premise/cloud

Sampling and deliverables tailored to needs and timelines

- Focus on high-privilege users, deliver 3 reports within 30 business days, review meetings for approval





Challenges and Solutions in SAP Development

Common challenges: limited resources, shifting threats, multiple stakeholders, regulatory changes

- Includes issues like scope creep or disagreements over assessment depth

Solutions involve clear documentation and formal approvals for scope changes

- Risk-based justification and communication balance stakeholder demands

SAP must adapt to emerging technologies and new risks

- Regular reviews and updates keep the SAP relevant and effective

Conclusion and Recap

SAP shapes the effectiveness of security evaluations

- Defines objectives, scope, methodology, controls, sampling, deliverables, timelines, and approval

Well-structured SAP ensures focused, efficient, credible assessments

- Facilitates communication and confidence among stakeholders

Flexibility, detail, and open communication are key to overcoming challenges

- Applying SAP principles leads to meaningful, actionable assessments

